Digitalisation Risk and Business Continuity for Pampered Pets

1. Purpose and headline findings

Digitalisation makes at least one quality failure or supply chain disruption likely in any year, but four controls cut the expected loss by about three-quarters. This summary gives Cathy those probabilities, in terms she can share with both royal customers and the continuity design MS Oduor requested.

- **Quality:** 38% annual probability of at least one quality event, and 25% for a contaminated batch reaching a customer.
- **Supply chain:** 54% annual probability of at least one disruption.
- **Loss:** £294,000 expected per year; one year in twenty costs £1.34 million or more.
- **With the recommended controls:** 13%, 32% and £68,000 respectively.
- **Continuity:** an active-active design across three cloud regions, with consensus replication, meets both one-minute targets. Standby designs do not.

Monetary figures are illustrative, and every probability rests on the assumptions

in section 3.

2. Risks and modelling approach

There are six risks that follow from the two changes Cathy has made: an international supply chain and automated warehouses.

ID	Risk	Why Digitalisation raises it
Q1	Contaminated batch reaches a customer	Manual inspection at the shop is replaced by remote, automated handling
Q2	Storage failure spoils stock in an automated warehouse	Temperature and handling now depend on sensors and software
S1	Inbound shipment late enough to cause a stock-out	Ingredients and stock now cross borders by sea
S2	Critical supplier or logistics partner fails	More suppliers, tiers and countries each raise disruption frequency **(Bode and Wagner, 2015)**
S3	Ransomware stops warehouse operations	Warehouses are networked and software-controlled
S4	Cyber compromise through a third party	Suppliers hold credentials and data connections

Method chosen: Monte Carlo simulation of a frequency and severity model. Each risk is given a range for how often it occurs and a range for what it costs. The simulation then plays out 200,000 possible years.

Three reasons support this choice over a risk matrix or a single expected-loss figure:

1. **Matrices can mislead. Cox (2008)** shows that risk matrices can give the same rating to very different risks and can rank a smaller risk above a larger one.

2. **It suits sparse data.** The business has no operating history for its new warehouses. **Aven (2016)** argues that a probability should be reported with the strength of knowledge behind it; ranges do that, and single numbers do not.

3. **It shows the tail.** Simulation yields a full loss distribution, so the board sees the bad year as well as the average year **(Olson and Wu, 2020).** This follows the quantitative approaches to supply chain risk reviewed by **Heckmann, Comes and Nickel (2015).**

3. Calculations, assumptions and data

For each risk, the number of events in a year is drawn from a Poisson distribution and each event's cost from a lognormal distribution:

$$L = \sum_{i=1}^{6} \sum_{j=1}^{N_i} X_{ij}, \qquad N_i \sim \text{Poisson}(\lambda_i), \qquad X_{ij} \sim \text{Lognormal}(\mu_i, \sigma_i)$$

The rate λ is itself uncertain, so it is drawn from a triangular distribution (lowest, most likely, highest). We use a lognormal distribution because reported incident costs are heavily skewed, with a mean far above the median **(Romanosky, 2016).** Its parameters are set so that 90% of events fall inside the stated range. The probability of at least one event in a year is 1 − exp(−λ).

ID	Events per year (low/likely/high)	Basis for the rate	Cost per event, 90% range
Q1	0.02 / 0.19 / 0.67	24 batches a year × share contaminated (3–14%, centred on 15 of 196 raw pet food samples positive for Salmonella; Nemser et al., 2014) × share escaping inspection (3–20%, assumed)	£100k–£2m
Q2	0.05 / 0.15 / 0.40	Assumed; no published rate found	£5k–£60k
S1	0.20 / 0.38 / 0.70	24 shipments × 40% of liner vessels arriving at least a day late **(Vernimmen, Dullaert and Engelen, 2007)** × share late enough to cause a stock-out (4%, assumed)	£10k–£120k
S2	0.10 / 0.25 / 0.45	Assumed; the literature gives direction but no per-firm rate **(Bode and Wagner, 2015)**	£30k–£400k
S3	0.01 / 0.04 / 0.07	24% of surveyed businesses reported cyber extortion in a year × 15–20% rating operational harm as serious **(Paoli, Visschers and Verstraete, 2018)**	£100k–£1.5m
S4	0.01 / 0.04 / 0.09	50% reported illegal access × 15–20% serious (same survey) × share entering through a supplier (30–60%, assumed)	£20k–£500k

General assumptions:

- The business ships fresh or raw products in 24 production batches and receives 24 sea shipments a year.
- Cost ranges are the author's estimates. The S3 and S4 ranges bracket the median cyber incident cost of US$0.25 million reported by **Romanosky (2016).** The S2

range reflects evidence that disruptions do lasting financial damage **(Hendricks and Singhal, 2005).**

- Risks are independent in the baseline. A second run applies a shared shock to all rates, to represent a bad year in which a cyber incident also delays deliveries.
- The treated run assumes test-and-hold release cuts Q1 escapes to 0.5–3%, that the other controls halve each remaining rate, and that immutable backups cut S3 cost by 60%.

4. Results

A contaminated batch (Q1) is one of the two most likely events and by far the most expensive, at 68% of expected annual loss.

ID	Risk	Annual probability	Expected annual loss	Probability with controls
Q1	Contaminated batch reaches a customer	25%	£200k	4%
Q2	Warehouse storage failure	18%	£5k	9%
S1	Shipment late enough to cause a stock-out	35%	£20k	19%
S2	Critical supplier failure	23%	£40k	12%
S3	Ransomware stops warehouses	4%	£22k	2%
S4	Third-party cyber compromise	5%	£8k	2%

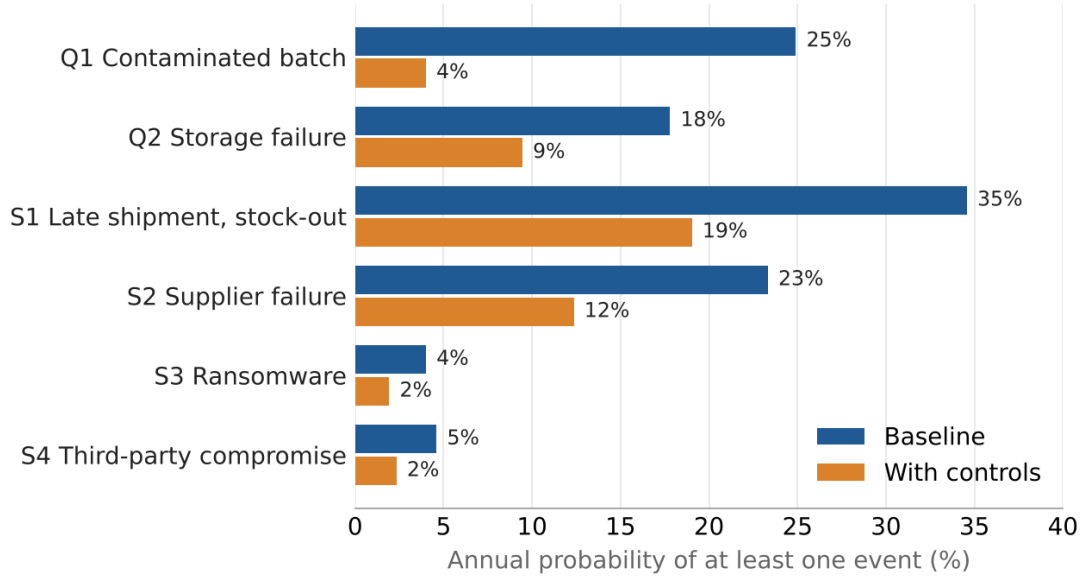


Figure 1: Annual probability of each risk, before and after the recommended controls.

Measure	Baseline	Risks correlated	With controls
At least one quality event	38%	36%	13%
At least one supply chain event	54%	51%	32%
Expected annual loss	£294k	£292k	£68k
Loss in the median year	£68k	£54k	£0
Loss exceeded one year in 20	£1.34m	£1.39m	£321k
Loss exceeded one year in 100	£2.82m	£2.90m	£968k
Probability of losing over £1m	8.0%	8.2%	0.9%

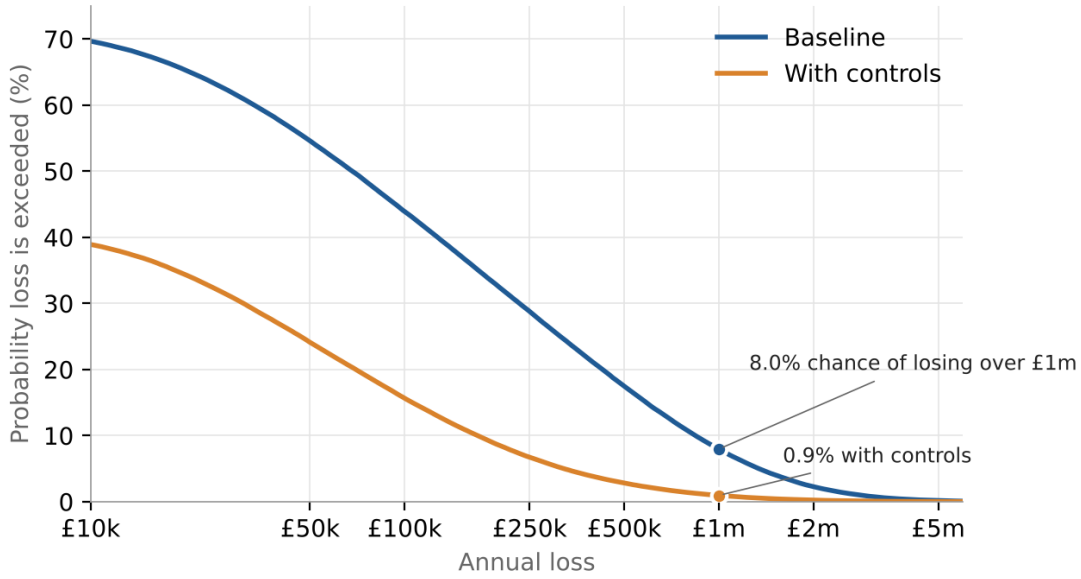


Figure 2: Probability that annual loss exceeds a given amount.

Results were stable to within about 1% across three further random seeds.

5. Findings and recommendations

Loss of quality: 38% a year, falling to 13%. The dominant cause is contamination that inspection misses. The recommendation is test-and-hold release: no batch ships until an accredited laboratory result is back, with batch-level traceability so a recall can be limited to affected orders. This single control removes most of the expected loss and is the assurance both royal customers are asking for.

Supply chain issues: 54% a year, falling to 32%. In order of probability:

1. Shipment late enough to cause a stock-out, 35%. Hold safety stock equal to three weeks of demand.

2. Critical supplier failure, 23%. Dual-source every critical ingredient and component.

3. Third-party cyber compromise, 5%. Set security terms in supplier contracts.
4. Ransomware stopping warehouses, 4%. Segment warehouse networks and keep immutable backups.

Delays are frequent but cheap; ransomware is rare but costly. Ranking by probability alone would therefore misdirect spending, which is why section 8 ranks by commercial impact.

How far to trust these figures. Three limits matter:

- **One assumption drives the result.** Moving the Q1 rate across its range shifts expected loss from £108k to £548k, and no other input moves it by more than £52k (Figure 3). The escape rate behind Q1 is assumed, so it should be measured in the first quarter and the model updated.
- **The data are borrowed.** The contamination figure comes from a United States sample of raw products. The cyber rates come from 310 self-selected Belgian firms surveyed in 2016, and the shipping figure dates from 2007.
- **Dependence is simplified.** Correlating the risks barely moved the average but worsened the 1-in-100-year by £80,000. Real dependence, for example, ransomware causing delays, may be stronger.

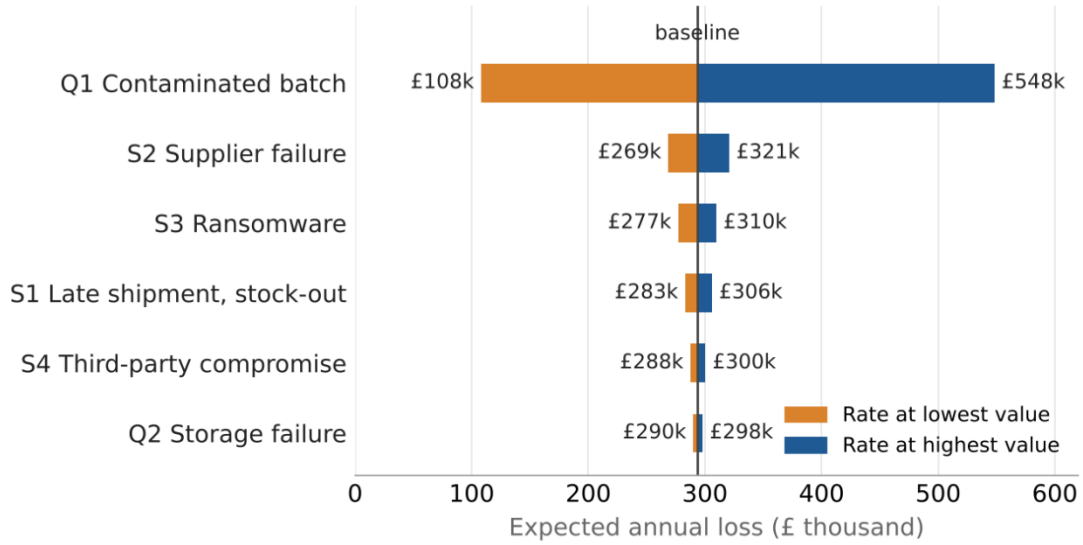


Figure 3: Sensitivity of expected annual loss to each risk's event rate.

The probabilities should be read as informed estimates with wide margins, not forecasts.

6. Business continuity and disaster recovery

Requirement. The online shop must run continuously, switch over in under one minute (recovery time objective, RTO) and lose under one minute of data (recovery point objective, RPO).

Design: active-active with consensus replication. Wood et al. (2010) set out the trade-off. Losing no data requires continuous synchronous replication, and only a hot site that is already running gives a minimal RTO. Warm standby servers take minutes to bring online, which fails the one-minute target (Figure 4). The design therefore keeps every site live.

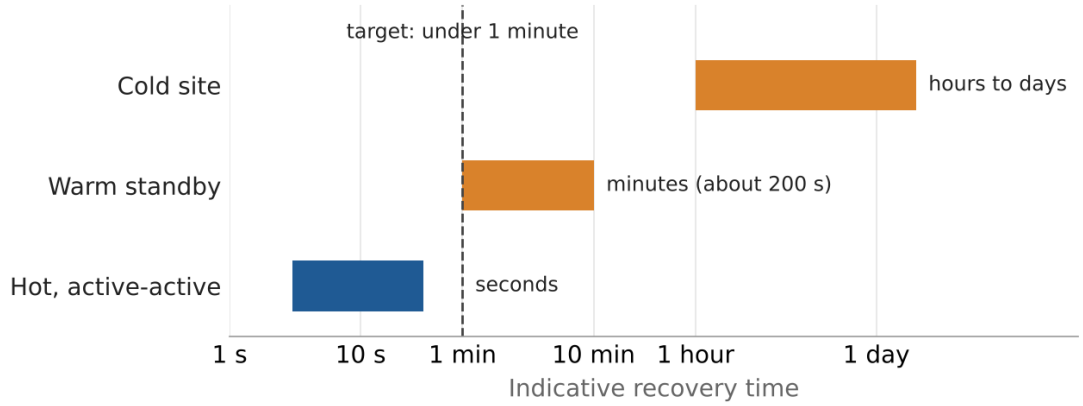


Figure 4: Indicative recovery time by DR strategy against the one-minute target

Layer	**Choice**	**How it meets the target**
Traffic	Fixed anycast addresses with health checks	DNS answers stay cached for their time-to-live, so DNS-only failover cannot guarantee a one-minute switch **(Moura et al., 2019)**
Application	Stateless containers on Kubernetes in three regions	Any two regions can carry full load
Database	CockroachDB, one replica per region	Each write is committed by Raft consensus to a majority of replicas, so losing a region loses no committed data **(Taft et al., 2020)**
Backup	Immutable daily backups in a separate account	Protects against corruption and ransomware, which replication would copy

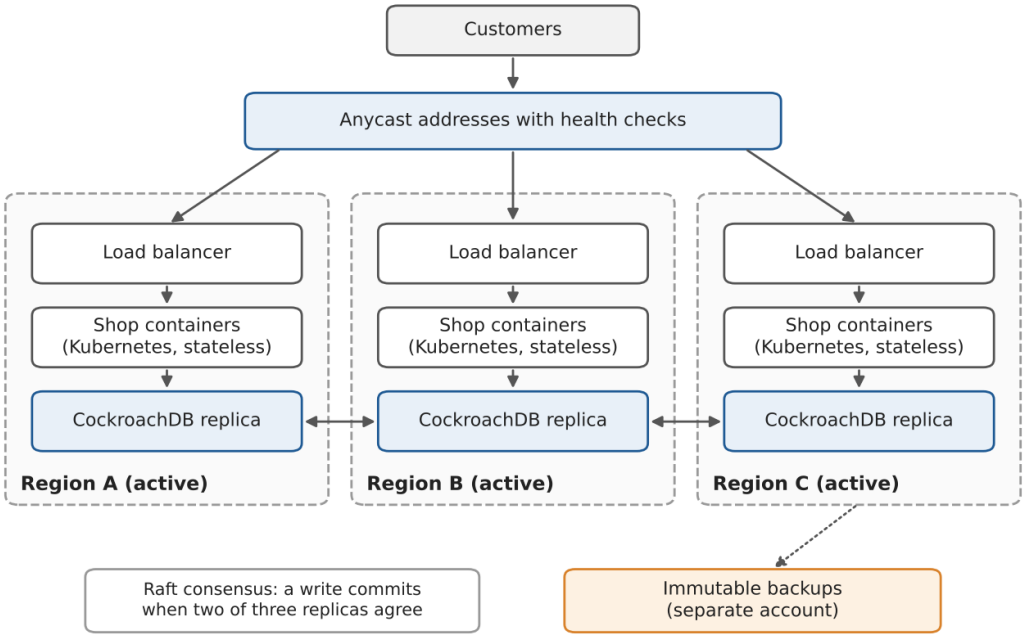


Figure 5: Proposed active-active disaster recovery architecture.

Limits of the design: Two points need care. First, **Wood et al. (2010)** note that synchronous replication slows as sites move apart, so the three regions should sit within one continent. Second, **Taft et al. (2020)** report lease renewals of nine seconds but no end-to-end failover time. The one-minute targets are therefore design goals until tested: a region failure should be simulated before launch and every quarter after.

Platform recommended: Host on one major public cloud with three European regions, and run CockroachDB on it. AWS is proposed for the hosting layer. That choice is a judgement, since the design does not depend on any AWS-only service.

Vendor lock-in: Lock-in arises mainly from proprietary services and data formats, and from the cost of moving data out **(Opara-Martins, Sahandi and Tian, 2016).** The design limits it in four ways:

1. The database is cloud-neutral: one cluster can span several public and private clouds **(Taft et al., 2020).**
2. It supports much of the PostgreSQL dialect, so the application is not tied to one product. Some client changes, such as transaction retries, are still needed.
3. The application runs in containers, and the infrastructure is defined as code, so it can be redeployed elsewhere.
4. Data is exported weekly in an open format, and the exit plan is rehearsed annually.

7. Security standards and data protection

The following are business requirements, not options. The brief's "new GDPR" is read as the UK GDPR, which keeps the duties of the EU regulation summarised by **Hoofnagle, van der Sloot and Zuiderveen Borgesius (2019).**

Requirement	**What the business must do**
Security of processing (Article 32)	Apply security appropriate to the risk: encryption, access control, tested restoration
Impact assessment (Article 35)	Complete a data protection impact assessment before the warehouses and shop go live
Breach notification (Article 33)	Be able to report a personal data breach to the regulator within 72 hours
International transfers (Chapter V)	Use an approved transfer mechanism for data sent to overseas warehouses or suppliers, and document the risk assessment
PCI DSS	Use a certified payment provider so card data never touches company systems
ISO/IEC 27001 (Culot et al., 2021) and ISO 22301	Align security and continuity management to these standards; certify once operations are stable

Royal customers raise the consequence of any breach, so their order data should have restricted access and separate logging.

8. Recommendations in priority order

Ranked by commercial impact, with the standard each one satisfies.

Priority	Action	Benefit	Standard met	When
1	Test-and-hold batch release with traceability	Quality risk 38% to 13%; removes most expected loss	Customer assurance	Before first international shipment
2	Active-active DR across three regions, with quarterly failover tests	Shop stays online; RTO and RPO under one minute	ISO 22301, UK GDPR Article 32	Before launch
3	Impact assessment, transfer agreements, certified payment provider	Lawful operation; avoids regulatory penalty	UK GDPR Articles 33 and 35, PCI DSS	Before launch
4	Network segmentation and immutable backups for warehouses	Cuts ransomware cost by an assumed 60%	ISO/IEC 27001, Article 32	Within 3 months
5	Dual sourcing and three weeks of safety stock	Supply chain risk 54% to 32%	ISO 22301	Within 6 months
6	Supplier security terms and annual review	Reduces third-party compromise	ISO/IEC 27001	Within 6 months

Priority	Action	Benefit	Standard met	When
7	Measure escape and delay rates; update the model quarterly	Replaces assumptions with evidence	ISO/IEC 27001 risk assessment	Ongoing

Together these reduce the probability of losing more than £1 million in a year from about 8% to about 1%.

References:

1. Aven, T. (2016) Risk assessment and risk management: Review of recent advances on their foundation. *European Journal of Operational Research* 253(1): 1–13. DOI: https://doi.org/10.1016/j.ejor.2015.12.023
2. Bode, C. & Wagner, S.M. (2015) Structural drivers of upstream supply chain complexity and the frequency of supply chain disruptions. *Journal of Operations Management* 36(1): 215–228.
3. Cox, L.A. (2008) What's wrong with risk matrices? *Risk Analysis* 28(2): 497–512. DOI: https://doi.org/10.1111/j.1539-6924.2008.01030.x
4. Culot, G., Nassimbeni, G., Podrecca, M. & Sartor, M. (2021) The ISO/IEC 27001 information security management standard: literature review and theory-based research agenda. *The TQM Journal* 33(7): 76–105. DOI: https://doi.org/10.1108/TQM-09-2020-0202
5. Heckmann, I., Comes, T. & Nickel, S. (2015) A critical review on supply chain risk – Definition, measure and modeling. *Omega* 52: 119–132. DOI: https://doi.org/10.1016/j.omega.2014.10.004
6. Hendricks, K.B. & Singhal, V.R. (2005) An empirical analysis of the effect of supply chain disruptions on long-run stock price performance and equity risk of the firm. *Production and Operations Management* 14(1): 35–52.
7. Hoofnagle, C.J., van der Sloot, B. & Zuiderveen Borgesius, F. (2019) The European Union general data protection regulation: what it is and what it means. *Information & Communications Technology Law* 28(1): 65–98.
8. Moura, G.C.M., Heidemann, J., Schmidt, R. de O. & Hardaker, W. (2019) 'Cache Me If You Can: Effects of DNS Time-to-Live', *Proceedings of the ACM Internet Measurement Conference*. Amsterdam, 21–23 October. New York: ACM. 101–115. DOI: https://doi.org/10.1145/3355369.3355568

9. Nemser, S.M. et al. (2014) Investigation of Listeria, Salmonella, and toxigenic Escherichia coli in various pet foods. *Foodborne Pathogens and Disease* 11(9): 706–709. DOI: https://doi.org/10.1089/fpd.2014.1748
10. Olson, D.L. & Wu, D. (2020) *Enterprise Risk Management Models*. 3rd ed. Berlin: Springer.
11. Opara-Martins, J., Sahandi, R. & Tian, F. (2016) Critical analysis of vendor lock-in and its impact on cloud computing migration: a business perspective. *Journal of Cloud Computing* 5(1): 4. DOI: https://doi.org/10.1186/s13677-016-0054-z
12. Paoli, L., Visschers, J. & Verstraete, C. (2018) The impact of cybercrime on businesses: a novel conceptual framework and its application to Belgium. *Crime, Law and Social Change* 70(4): 397–420. DOI: https://doi.org/10.1007/s10611-018-9774-y
13. Romanosky, S. (2016) Examining the costs and causes of cyber incidents. *Journal of Cybersecurity* 2(2): 121–135. DOI: https://doi.org/10.1093/cybsec/tyw001
14. Taft, R. et al. (2020) 'CockroachDB: The Resilient Geo-Distributed SQL Database', *Proceedings of the 2020 ACM SIGMOD International Conference on Management of Data*. Portland, 14–19 June. New York: ACM. 1493–1509. DOI: https://doi.org/10.1145/3318464.3386134
15. Vernimmen, B., Dullaert, W. & Engelen, S. (2007) Schedule unreliability in liner shipping: Origins and consequences for the hinterland supply chain. *Maritime Economics & Logistics* 9(3): 193–213. DOI: https://doi.org/10.1057/palgrave.mel.9100182
16. Wood, T., Cecchet, E., Ramakrishnan, K.K., Shenoy, P., van der Merwe, J. & Venkataramani, A. (2010) 'Disaster Recovery as a Cloud Service: Economic Benefits & Deployment Challenges', *2nd USENIX Workshop on Hot Topics in Cloud Computing (HotCloud 10)*. Boston, 22 June. Berkeley: USENIX Association.